

SC EXAM PREP — PREDICTED 2026

AI駆動型サイバー攻撃・フロンティアAI

自律型攻撃/防御/デュアルユース/悪用リードタイム短縮/防御AIのHITLガバナンス。2026年のフロンティアAI登場で現実化した「攻撃と防御のAI化」を5問で体系学習する。

Q1・Governance

デュアルユースとフロンティアAIの公開制限

頻出 ★★★

Q2・Vuln Mgmt

悪用リードタイム短縮への対応

頻出 ★★★

Q3・Chaining

低スコア脆弱性の連鎖と攻撃経路

頻出 ★★☆

Q4・SOC AI

自律型防御エージェントとHITL

頻出 ★★★

Q5・Least Priv

防御AIエージェントへの権限付与原則

頻出 ★★☆

 基礎概念 5枚  問題演習 5問  統合サマリー  2026 春・秋 想定

※ 過去問傾向(令和3～7年)と最新動向をもとにAIが作成した予想問題です。実際の試験問題ではありません。最終確認を推奨します。



学習マップ — 5問の相互関係

MAP

「攻撃のAI化」→「守りの立て直し」→「防御のAI化ガバナンス」の学習動線

Q1

デュアルユース

脆弱性発見・悪用能力の高いAIは攻守両用。ゆえに提供を防御目的組織に限定

フロンティアAI統制



Q2

リードタイム

発見～悪用の自動化・高速化で公表～悪用の時間差が縮む
→パッチ運用見直し

リスクベース脆弱性管理



Q3

連鎖(チェーン)

低スコア脆弱性の組合せで権限昇格。CVSS閾値でなく攻撃経路で優先度

コンテキスト依存の優先度



Q4

SOC自律AI

検知～遮断を自律実行。誤検知で業務停止のリスク→高影響操作はHITL+監査

防御AIのガバナンス



Q5

最小権限

エージェントの誤動作・乗っ取り時の被害を限定。付与権限を必要最小限に

least privilege

STEP 1 | WHY

AIで「発見～悪用」が自動化・高速化し、攻守が同一能力で回るデュアルユース構造を理解する

STEP 2 | HOW

5問で「攻撃AI化への守り」と「防御AIのガバナンス」を判別し、ひっかけ選択肢を切る

STEP 3 | WHAT

空・雨・傘で対策(適用迅速化・攻撃経路優先・HITL・最小権限・監査)へ落とす

① 基礎概念 — 攻撃/防御のAI化 全体像

「攻撃ライフサイクル」×「攻撃側/防御側のAI化」の2軸で本デッキ5問を配置

CONCEPT

局面	攻撃側のAI化 (オフェンス)	防御側のAI化・ガバナンス (ディフェンス)
脆弱性の発見	脆弱性を自律的に発見(専門家を上回る能力)	Q1 デュアルユース→フロンティアAIの提供を防御目的組織に限定
悪用/武器化	Q2 実証コードを自動生成→公表～悪用のリードタイム短縮	リスクベースで適用サイクルを短縮(月次一括では間に合わない)
攻撃設計	Q3 低スコア脆弱性を連鎖(チェーン)し権限昇格	自社構成の攻撃経路・連鎖を踏まえ優先順位付け
検知～対応	攻撃の高速化・自動化で対応遅延が致命傷に	Q4 SOCで検知～遮断を自律実行 + Q5 最小権限・HITL・監査

核心: 脆弱性発見・悪用能力の高いAIは**防御(自組織の診断・修正)**にも**攻撃(第三者侵害)**にも使えるデュアルユース技術。攻撃のAI化は「①悪用リードタイム短縮」「②低スコア脆弱性の連鎖」で守りを崩し、防御のAI化は「③自律対応の高速化」と引き換えに「④誤検知・乗っ取りのガバナンス」を要求する。

② 基礎概念 — 混同しやすい概念 比較表

「正しい対応」と「もっともらしい誤答」を5ペアで対比

CONCEPT

対象概念	● 概念A (適切)	● 概念B (ひっかけ)
攻撃AI化の本質	公表～悪用のリードタイムが短縮し無防備期間が拡大	「試行頻度が下がる」「IPS更新を減らせる」など逆の効果と誤解
脆弱性の選別	攻撃経路・連鎖と資産の重要度でリスクベースに優先度付け	CVSS基本値が閾値以上のみ対応＝連鎖リスクを見落とす
フロンティアAI提供	デュアルユース性ゆえ防御目的組織に限定してアクセス許可	「推論コスト」「個人情報保護法」を本質理由と誤認
SOC自動化の範囲	影響大の対応は人間承認(HITL)を挟み判断根拠を記録	「AIは常に正確」と全自動実行＝誤検知で業務停止
エージェント権限	最小権限で乗っ取り・誤動作時の被害範囲を限定	迅速化のため管理者権限を常時付与＝被害拡大

フロンティアAI Frontier AI

脆弱性の自律的発見・攻撃コード生成などで人間の専門家を上回り得る高性能モデル。能力が一定水準を超えると悪用時の被害が甚大化する。

 高能力の最先端AI

悪用リードタイム Time-to-Exploit

脆弱性の公表から悪用開始までの期間。AIによる発見～悪用の自動化で短縮し、月次一括のバッチ運用では無防備期間が生じる。

 公表→悪用の時間差

リスクベース脆弱性管理 RBVM

CVSS基本値の閾値だけでなく、悪用可能性(露出)・資産の重要度・攻撃経路で対応の優先度を決める考え方。

 悪用可能性×重要度

最小権限の原則 Least Privilege

業務遂行に必要な最小限の権限のみ付与。エージェントの誤動作・乗っ取り時の被害範囲を限定する。

 被害範囲の限定

デュアルユース Dual-use

防御(診断・修正)にも攻撃(第三者侵害)にも使える両義性。武器化の恐れから提供先を防御目的組織に限定する運用の根拠となる。

 軍民・攻守両用性

脆弱性の連鎖 Vulnerability Chaining

単体ではCVSS基本値が低い複数脆弱性を組み合わせ、権限昇格など深刻な攻撃を成立させる手法。

 チェーン攻撃

human-in-the-loop HITL

影響の大きい/不可逆な対応(本番遮断・アカウント無効化等)の実行前に人間の承認を挟む統制。誤検知の業務停止を防ぐ。

 人間の承認組み込み

自律型AIエージェント Autonomous SOC Agent

SOARに加え、検知内容の分析・影響範囲調査・隔離/無効化までを自律実行。速度と引換えにガバナンスが要る。

 検知～対応の自律化

④ 基礎概念 — 規格・規制・優先度指標マトリクス

「AIガバナンス」と「脆弱性優先度」の道具を混同しない

CONCEPT

名称	種別	要点 (試験での問われ方)
NIST AI RMF	AIリスク管理FW	GOVERN/MAP/MEASURE/MANAGEでAIリスクを管理。攻撃TTP体系や認証規格ではない。
ISO/IEC 42001	認証規格(AIMS)	AIマネジメントシステムの認証規格。ISMS(27001)のAI版という位置づけ。
AI事業者ガイドライン	国内ガイドライン	総務省・経産省。開発者/提供者/利用者の3主体区分。組織統制・デュアルユース対応の根拠。
フロンティアAI安全性の枠組	提供者の自主的取組	危険能力の評価と、閾値超過時の提供制限等のリスク低減策。Q1の背景。
CISA KEV / EPSS	悪用可能性の指標	実際に悪用された脆弱性(KEV)・悪用確率(EPSS)。リードタイム短縮時代の優先度付けに有効。
CVSS 基本値	深刻度の指標	単体の深刻度。閾値のみでの選別は連鎖リスクを見落とす=Q3のひっかけ源。

💡 頻出の軸: 「AIリスク管理=AI RMF」「認証規格=42001」「国内統制=AI事業者ガイドライン」の3分類と、脆弱性優先度は「深刻度=CVSS」「悪用可能性=KEV/EPSS」「連鎖=攻撃経路」で切り分ける。CVSS一本での判断が4択・記述の定番ひっかけ。



試験のコツ & 頻出ひっかけ

Exam Strategy & Common Pitfalls

TIPS

✓ 解くコツ

1. 攻撃AI化の本質は「リードタイム短縮」と「連鎖による深刻化」。この2語で正解を選ぶ。
2. 優先度は悪用可能性(露出)×資産の重要度×攻撃経路。CVSS高い順「のみ」は誤答。
3. フロンティアAIの提供制限の理由はデュアルユース性。コスト・法令は本質理由でない。
4. 防御AIの自律化は「速度」と「HITL・最小権限・監査」をセットで語る。

⚠ よくあるひっかけ

- 「攻撃頻度が下がる」「IPS更新を減らせる」「IPブロックで十分」は逆・過小評価。
- 「AIは既知脆弱性しか悪用できない」→ゼロデイ発見にも使われ得るので誤り。
- 「低評価の脆弱性は恒久的に見送り」「全て一律同期限」は両極端で不適切。
- 「AIは常に人間より正確」「管理者権限を常時付与」「手順書は不要」はガバナンス放棄。

合言葉: 攻めは「リードタイム短縮×連鎖」、守りは「リスクベース優先度+HITL・最小権限・監査」。極端な断定(「常に」「全て」「不要」「十分」)の選択肢は**まず疑う**。

ソフトウェア脆弱性の自律的な発見と実証コード(エクスプロイト)生成において人間の専門家を上回る能力をもつAIモデルについて、開発元が一般公開やAPI提供を行わず、防御目的の組織に限定してアクセスを許可する運用を採ることがある。この判断の主な理由はどれか。

ア モデルの推論コストが高く、一般提供では採算が取れないため

イ 防御にも攻撃にも利用できるデュアルユース性を持ち、攻撃者の手に渡った場合に脆弱性の武器化が大規模かつ高速に行われるおそれがあるため

ウ 学習データに個人情報が含まれ、個人情報保護法の第三者提供制限に抵触するため

エ 生成する攻撃コードの品質が低く、誤検知を誘発して防御側の運用を妨げるため

正解 イ ア=採算/ウ=法令/エ=品質は、いずれも本質的な理由ではない

▲ 空 (事実)

脆弱性発見・悪用能力の高いAIは、自組織の診断・修正にも第三者への侵害にも使える。

● 雨 (解釈)

能力が一定水準を超えると悪用時の被害が甚大化する。ゆえに提供先を絞るのはリスク低減策。

✦ 傘 (対策)

危険能力の評価と閾値超過時のアクセス制限。防御目的組織に限定して提供する。

攻撃側がAIを活用して脆弱性の発見から悪用までを自動化・高速化する状況が、企業の脆弱性管理に与える影響として、最も適切なものはどれか。

ア 攻撃の試行頻度が下がるため、IPSのシグネチャ更新頻度を下げてもよい

イ 脆弱性公表から悪用開始までのリードタイムが短縮するため、修正適用までの許容時間を見直し、悪用可能性に基づく優先順位付けと適用の迅速化が必要になる

ウ AIは既知の脆弱性しか悪用できないため、ゼロデイ攻撃への対策は不要になる

エ 攻撃が自動化されると攻撃元IPが固定されるため、IPアドレスブロックだけで十分な防御となる

正解 イ ア=更新は不要にならない/ウ=ゼロデイ発見にも用いられ得る/エ=IPブロックのみでは不十分

空 (事実)

AIによる自動化で、発見から悪用までの時間が大幅に短縮する。

雨 (解釈)

月次一括のような固定サイクルでは間に合わず、無防備な期間が生じる。

傘 (対策)

悪用可能性・資産の重要度によるリスクベースの優先順位付けと適用サイクルの短縮。

実務メモ: 午後の直球テーマ。「四半期一括適用」の危険性を「リードタイム短縮=無防備期間」で説明できるかが分水嶺。KEV/EPSSでの優先度付けと結び付けたい。

AIによる脆弱性分析では、単体ではCVSS基本値が低い複数の脆弱性を組み合わせて(チェーンして)権限昇格などの深刻な攻撃を成立させる能力が示されている。この状況を踏まえた脆弱性対応の考え方として、最も適切なものはどれか。

ア CVSS基本値が一定値以上の脆弱性のみを対応対象とすれば十分である

イ 低重要度の脆弱性は悪用されないので、対応を恒久的に見送ってよい

ウ 個々のスコアだけでなく、自社システムの構成における攻撃経路(複数脆弱性の連鎖を含む)を考慮して対応の優先順位を決める

エ すべての脆弱性に対して、重要度にかかわらず同一の期限で一律に対応する

正解 ウ ア・イ=閾値/軽視で連鎖を見落とす/エ=リソース有限で非現実的

▲ 空 (事実)

単体では低リスクに見える脆弱性でも、連鎖により深刻な侵害が成立し得る。

☂ 雨 (解釈)

CVSS基本値の閾値のみでの選別は連鎖リスクを見落とす。一方で一律対応も現実的でない。

☂ 傘 (対策)

自社固有の構成・攻撃シナリオ(攻撃経路)に基づき優先順位を決める。

SOCにおいて、検知から遮断までを自律的に実行するAIエージェントを導入する場合の留意点として、最も適切なものはどれか。

ア AIの判断は常に人間より正確なので、遮断の実行に人間の承認を挟む必要はない

イ 誤検知で正常業務が停止するリスクがあるため、影響の大きい対応(本番システムの遮断等)には人間の承認を組み込み、AIの判断根拠を記録・監査できるようにする

ウ AIエージェントには管理者権限を常時付与し、あらゆる対応を即時実行できるようにすべきである

エ AIエージェントを導入すれば、インシデント対応手順書や体制の整備は不要になる

正解 イ ア=承認省略は誤検知に無防備/ウ=常時管理者権限は被害拡大/エ=手順・体制は必要

空 (事実)

防御の自動化は対応の高速化に有効だが、誤検知時に正常業務を止めるリスクを伴う。

雨 (解釈)

影響度に応じてHITL(人間承認)を組み込むことが、防御AI運用のガバナンスの要点。

傘 (対策)

影響大の対応は人間承認 + 最小権限 + 判断根拠のログ記録・監査可能性を確保。

SOCに導入する自律型対応AIエージェントへ付与する権限について、誤動作や乗っ取り(注入指示等)が生じた場合の被害範囲を限定する観点から、最も適切な原則はどれか。

ア 対応の迅速化を最優先し、エージェントに管理者権限を常時付与する

イ 業務遂行に必要な最小限の権限のみを付与し、権限外の実行をできないようにする
(最小権限の原則)

ウ あらゆる操作を人手を介さず即時自動実行できるよう、権限の制限を撤廃する

エ 処理を高速化するため、判断根拠や操作履歴のログ記録を省略する

正解 イ ア=常時管理者権限は被害拡大/ウ=制限撤廃は逆効果/エ=監査可能性を損なう

▲ 空 (事実)

エージェントに与えた権限が過大だと、誤動作や乗っ取り時の被害が拡大する。

☂ 雨 (解釈)

最小権限は被害範囲を局所化する統制の基本。乗っ取り成立時も影響を限定できる。

☂ 傘 (対策)

業務に必要な最小権限のみ付与+権限分離。高影響操作はHITL、操作は監査ログ化。

📁 実務メモ: Q4(HITL・監査)と対で、防御AIガバナンスは「最小権限+人間承認+ログ」の3点セット。理由は必ず「誤動作・乗っ取り時の被害範囲の限定」で書く。



午後 記述式 — シナリオ要点

K社 脆弱性管理体制の見直し / S社 防御AIエージェント・ガバナンス

記述

◆ 問1 (春想定) K社 脆弱性管理の見直し

- 設問1 = 四半期一括が危険な理由: 悪用開始までのリードタイムが短縮し、次回適用まで無防備な期間が生じるから。
- 設問2 = 優先順位の観点2つ: ①悪用可能性(外部公開資産など露出) ②影響資産の事業上の重要度(脅威情報も可)。
- 設問3 = 低CVSSも対応要の理由: AIが複数の低評価脆弱性を連鎖させ権限昇格など深刻な攻撃を成立させ得るから。

◆ 問2 (秋想定) S社 SOC 防御AIエージェント

- 設問1 = 完全自動化のリスク: 誤検知による自動遮断で正常業務(勘定系)が停止するおそれ。
- 設問2 = 設計方針: 影響が限定的な対応は自動実行、本番遮断など影響大は人間承認(HITL)を経て実行。
- 設問3 = 権限原則: 最小権限。理由 = 誤動作・乗っ取り時の被害範囲を限定するため。
- 設問4 = 記録事項: ①判断根拠(検知内容・入力情報) ②実行した対応内容と時刻(承認者含む操作履歴も可)。

採点の分水嶺: ①「リードタイム短縮=無防備期間」を結び付ける ②優先度は「露出×重要度」の2軸(CVSS高い順のみは不十分) ③低評価も「連鎖(チェーン)」で深刻化 ④防御AIは「影響度に応じたHITL+最小権限+判断根拠・実行内容のログ(監査可能性)」まで踏み込んでいるか。



総合サマリー — 頻出ヒートマップ & 総括

出題可能性 × 難易度でAI駆動型攻撃・フロンティアAI論点を俯瞰

SUMMARY

論点	出題可能性	難易度	対策語彙
デュアルユース／フロンティアAI提供制限	最有力	低	攻守両用・提供限定
悪用リードタイム短縮／脆弱性管理	最有力	中	リスクベース優先度
脆弱性の連鎖／攻撃経路	高	中	攻撃経路で優先度
SOC自律防御AI／HITL	最有力	高	影響度×人間承認
防御AIエージェントの最小権限・監査	高	中	最小権限+ログ

総括: 本分野は**午前IIの用語・構造理解**(デュアルユース／リードタイム短縮／連鎖／HITL)と、**午後の実務シナリオ**(脆弱性管理体制の見直し／SOCの防御AIガバナンス)の両輪で狙われる。攻めは「**リードタイム短縮×連鎖**」、守りは「**リスクベース優先度+HITL・最小権限・監査**」に集約。極端な断定選択肢を切る力を最優先で固めること。

※本デッキはAIが過去問傾向・最新動向をもとに作成した予想問題です。正解・解説・図解は最終確認を推奨します。ペンダー・製品名は本試験には登場しません。